

lab 14(DCL)

Task-1

A hospital maintains a database to manage patient records, doctor schedules, and billing. The database has the following tables:

1. Patients → PatientID, Name, Age, Gender, MedicalHistory
2. Appointments → AppointmentID, PatientID, DoctorID, AppointmentDate, Status
3. Billing → BillID, PatientID, Amount, PaymentStatus, PaymentMethod

Users and Roles:

- AdminUser → Full access to all tables
- DoctorUser → Can view patient info and appointments, update appointment status and medical history
- ReceptionUser → Can view patient info, manage appointments (insert/update), but cannot access billing or medical history
- AccountUser → Can view billing info and update payment status, but cannot access patient medical history Implement role-based access control using DCL to ensure data confidentiality and security, especially for sensitive medical and financial information.

Create Users:

```
CREATE USER AdminUser WITHOUT LOGIN;  
CREATE USER DoctorUser WITHOUT LOGIN;  
CREATE USER ReceptionUser WITHOUT LOGIN;  
CREATE USER AccountUser WITHOUT LOGIN;
```

Create Roles

```
CREATE ROLE AdminRole;  
CREATE ROLE DoctorRole;  
CREATE ROLE ReceptionRole;  
CREATE ROLE AccountRole;
```

Assign Users to Roles

```
ALTER ROLE AdminRole ADD MEMBER AdminUser;  
ALTER ROLE DoctorRole ADD MEMBER DoctorUser;  
ALTER ROLE ReceptionRole ADD MEMBER ReceptionUser;  
ALTER ROLE AccountRole ADD MEMBER AccountUser;
```

Grant Privileges:

1. Admin Role → Full access:

```
GRANT SELECT, INSERT, UPDATE, DELETE ON Patients TO AdminRole;  
GRANT SELECT, INSERT, UPDATE, DELETE ON Appointments TO AdminRole;  
GRANT SELECT, INSERT, UPDATE, DELETE ON Billing TO AdminRole;
```

2. Doctor Role → View patients & appointments, update medical history:

```
GRANT SELECT ON Patients TO DoctorRole;  
GRANT SELECT, UPDATE ON Appointments TO DoctorRole;  
GRANT UPDATE(MedicalHistory) ON Patients TO DoctorRole;
```

3. Reception Role → Manage appointments, view patient basic info:

```
GRANT SELECT(PatientID, Name, Age, Gender) ON Patients TO ReceptionRole;  
GRANT SELECT, INSERT, UPDATE ON Appointments TO ReceptionRole;
```

4. Account Role → Manage billing info:

```
GRANT SELECT, UPDATE(PaymentStatus) ON Billing TO AccountRole;  
GRANT SELECT(PatientID, Name) ON Patients TO AccountRole; -- Only for reference, not full details
```

Test:

1. Test DoctorUser:

```
EXECUTE AS USER = 'DoctorUser';  
-- Should be able to update medical history  
UPDATE Patients SET MedicalHistory = 'Updated' WHERE PatientID = 101;  
-- Should NOT be able to delete billing info  
DELETE FROM Billing WHERE BillID = 201;  
REVERT;
```

2. Test ReceptionUser:

```
EXECUTE AS USER = 'ReceptionUser';  
-- Should be able to insert appointment  
INSERT INTO Appointments(AppointmentID, PatientID, DoctorID, AppointmentDate, Status)  
VALUES(301, 101, 201, '2025-12-20', 'Scheduled');  
-- Should NOT view medical history  
SELECT MedicalHistory FROM Patients;  
REVERT;
```

3. Test AccountUser:

```
EXECUTE AS USER = 'AccountUser';  
-- Should be able to update payment status  
UPDATE Billing SET PaymentStatus = 'Paid' WHERE BillID = 201;  
-- Should NOT update patient medical history  
UPDATE Patients SET MedicalHistory = 'Test' WHERE PatientID = 101;  
REVERT;
```

Task 2

A multinational corporation maintains a database for HR and Payroll management. The database has multiple sensitive tables:

1. Employees → EmployeeID, Name, Department, Position, Salary, DateOfJoining
2. Departments → DepartmentID, DepartmentName, ManagerID
3. Payroll → PayrollID, EmployeeID, SalaryMonth, SalaryAmount, Bonus, TaxDeduction
4. Attendance → AttendanceID, EmployeeID, Date, Status

Users and Roles:

- AdminUser → Full control over all tables (HR Admin)
- HRUser → Can view and update employee and attendance records but cannot see salary details
- PayrollUser → Can view salary and payroll information, update bonus and tax details, but cannot modify employee personal info
- ManagerUser → Can view employees in their department, approve attendance, and view salary summary but cannot modify Payroll or HR details

Create Users:

```
CREATE USER AdminUser WITHOUT LOGIN;  
CREATE USER HRUser WITHOUT LOGIN;  
CREATE USER PayrollUser WITHOUT LOGIN;  
CREATE USER ManagerUser WITHOUT LOGIN;
```

Create Roles:

```
CREATE ROLE AdminRole;  
CREATE ROLE HRRole;  
CREATE ROLE PayrollRole;  
CREATE ROLE ManagerRole;
```

Assign Users to Roles:

```
ALTER ROLE AdminRole ADD MEMBER AdminUser;  
ALTER ROLE HRRole ADD MEMBER HRUser;  
ALTER ROLE PayrollRole ADD MEMBER PayrollUser;  
ALTER ROLE ManagerRole ADD MEMBER ManagerUser;
```

Grant Privileges:

1. Admin Role → Full access:

```
GRANT SELECT, INSERT, UPDATE, DELETE ON Employees TO AdminRole;  
GRANT SELECT, INSERT, UPDATE, DELETE ON Departments TO AdminRole;  
GRANT SELECT, INSERT, UPDATE, DELETE ON Payroll TO AdminRole;  
GRANT SELECT, INSERT, UPDATE, DELETE ON Attendance TO AdminRole;
```

2. HR Role → Manage employee info and attendance (but not payroll):

```
GRANT SELECT, UPDATE ON Employees TO HRRole;  
GRANT SELECT, INSERT, UPDATE ON Attendance TO HRRole;
```

3. Payroll Role → Manage payroll, view employees (restricted columns):

```
GRANT SELECT(EmployeeID, Name, Department) ON Employees TO PayrollRole; -- Restricted view  
GRANT SELECT, UPDATE(SalaryAmount, Bonus, TaxDeduction) ON Payroll TO PayrollRole;
```

4. Manager Role → View employees in their department and approve attendance:

```
GRANT SELECT(EmployeeID, Name, Department, Position) ON Employees TO ManagerRole;  
GRANT SELECT, UPDATE(Status) ON Attendance TO ManagerRole; -- Can approve attendance  
GRANT SELECT(SalaryAmount, Bonus) ON Payroll TO ManagerRole; -- Can view summary only
```

Test Access:

Test HRUser:

```
EXECUTE AS USER = 'HRUser';  
-- Can update attendance  
UPDATE Attendance SET Status = 'Present' WHERE EmployeeID = 101 AND Date = '2025-11-18';  
-- Cannot access Payroll  
SELECT * FROM Payroll;  
REVERT;
```

Test PayrollUser:

```
EXECUTE AS USER = 'PayrollUser';  
-- Can update bonus  
UPDATE Payroll SET Bonus = 500 WHERE EmployeeID = 101 AND SalaryMonth = '2025-11';  
-- Cannot update employee personal info  
UPDATE Employees SET Name = 'Ali' WHERE EmployeeID = 101;  
REVERT;
```

Test ManagerUser:

```
EXECUTE AS USER = 'ManagerUser';  
-- Can approve attendance  
UPDATE Attendance SET Status = 'Approved' WHERE EmployeeID = 101;  
-- Can view salary summary  
SELECT EmployeeID, SalaryAmount, Bonus FROM Payroll WHERE EmployeeID = 101;  
-- Cannot modify Payroll or Employee details  
UPDATE Payroll SET Bonus = 1000 WHERE EmployeeID = 101;  
REVERT;
```

Test AdminUser:

```
EXECUTE AS USER = 'AdminUser';  
-- Full access to all tables  
DELETE FROM Payroll WHERE PayrollID = 201;  
INSERT INTO Employees(EmployeeID, Name, Department, Position, Salary, DateOfJoining)  
VALUES(110, 'Sara', 'IT', 'Developer', 90000, '2025-01-15');  
REVERT;
```